

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Lab Assignment: Risk Management Fundamentals

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Introduction to GRC Engineering
Date Submitted	5 August, 2026

Lab Objectives:

This lab assignment is designed to help you:

- Understand the fundamental concepts of risk management in cybersecurity
- Apply risk identification, assessment, and mitigation methodologies
- Develop skills in creating risk matrices and prioritizing risks
- Gain practical experience in developing risk treatment plans

Instructions:

Complete all parts of this lab assignment. Submit your completed document to your instructor by the due date. All answers should be typed directly into this document.

Part 1: Risk Management Concepts (20 points)

1. Define the following terms in your own words and explain their relationship to each other: risk, threat, vulnerability, impact, and likelihood. (10 points)

Risk: This is the likelihood that something bad or harmful could happen and affect an organization's goals or operations. It is the chance that a threat could exploit a weakness in a system and cause damage.

Threat: This is anything that has the potential to cause harm to systems, data, or people. A threat can take advantage of a weakness in a system. Examples include malware, natural disasters, and cybercriminals.

Vulnerability: This is basically a weakness that can be exploited. It is a gap in a system, process, or security control that can be taken advantage of by a threat.

Impact: This is the level of damage that occurs if a risk happens. For example, it could lead to the disruption of business operations.

Likelihood: This is the probability that a threat will exploit a vulnerability. In other words, it is the chance that a particular risk will occur.

2. Compare and contrast qualitative and quantitative risk assessment methodologies. What are the advantages and disadvantages of each approach? When would you recommend using one over the other? (10 points)

Qualitative Risk Assessment uses ratings such as low, medium, and high to determine the level of risk. It is based on professional judgement, experience, and available information instead of numerical values. One advantage is that it is quick and does not require a lot of data. Qualitative Risk Assessment is a good option if an organization needs to identify and prioritize risks without spending too much time or money. For example, two people could look at the same risk and rate it differently based on their judgment.

Quantitative Risk Assessment uses numerical values and data to estimate risk. It can calculate the likelihood of an event, the financial impact, or the expected loss if a risk occurs. One major advantage is that it provides more convincing results that can support budgeting and business decisions. It also makes it easier to compare different risks using actual figures, which can be helpful when presenting to executives. The disadvantage is that it takes more time, requires reliable historical data, and can be more complex to carry out.

I would recommend using a **qualitative risk assessment** when an organization is first identifying and prioritizing risks, has limited data, or needs to make decisions quickly. A **quantitative risk assessment** is more suitable when accurate financial data is available and management needs a detailed analysis to support major business or security investments.

Part 2: Risk Identification Exercise (25 points)

For this exercise, consider a medium-sized financial services company that is planning to migrate its customer relationship management (CRM) system from an on-premises solution to a cloud-based service. The CRM system contains sensitive customer financial information and personally identifiable information (PII).

Identify at least 10 potential risks associated with this migration. For each risk, provide:

1. A clear risk statement
2. The risk category (e.g., technical, operational, compliance, reputational)
3. The potential threat source or actor

4. The vulnerability being exploited

Risk Statement	Risk Category	Threat Source/Actor	Vulnerability
Customer financial data or PII could be exposed during the migration process if the data is not properly encrypted or secured.	Technical	Cybercriminals (external attackers/hackers)	Data is transferred without strong encryption.
Unauthorized users could gain access to the cloud-based CRM and view or modify sensitive customer information.	Technical	Internal IT/cloud team (human error) or External attackers	Storage permissions were left at their default or overly open settings, with no automatic checks in place. There were also weak access controls and poor authentication measures.
Storing or processing data outside the required jurisdiction could put the company out of compliance with regulations like NDPR or GDPR.	Compliance	Regulatory authorities or gaps in the company's own compliance process	No clear policy on where customer data is allowed to be stored.
The cloud service may experience downtime, making the CRM unavailable to employees and affecting customer service.	Operational	Cloud service provider	Dependence on a single cloud service and limited availability planning.
The company could experience data loss during the migration, leading to incomplete or missing customer records.	Operational	Human error or system failure	Poor backup procedures and inadequate migration planning.
Someone on the inside with legitimate access could misuse it to view or steal customer data.	Operational	An employee or contractor, whether careless or intentionally malicious	Access control issues, with people having more access than they need for their job.
If a breach happens and becomes public, it could seriously damage	Reputational	Cybercriminals or hacktivists	No solid plan for how to respond and communicate if something goes wrong.

how customers see the company.			
Employees could fall for phishing attacks, allowing attackers to use stolen login credentials to access the cloud CRM.	Technical	Phishing attackers	No multi-factor authentication (MFA) is required on user accounts.
Employees may accidentally expose sensitive customer information due to a lack of training on the new cloud system.	Operational	Employees	Insufficient user awareness and training.
APIs connecting the CRM to other systems could be exploited if they are not properly secured.	Technical	Attackers targeting the API directly	APIs that are unpatched or don't have proper authentication in place.

Part 3: Risk Assessment Matrix (25 points)

From the risks you identified in Part 2, select the five most significant risks and complete the following risk assessment matrix. For each risk:

1. Assign a likelihood rating (1-5, where 1 is rare and 5 is almost certain)
2. Assign an impact rating (1-5, where 1 is negligible and 5 is severe)
3. Calculate the risk score (likelihood × impact)
4. Determine the risk level based on the score:
 - Low: 1-4
 - Medium: 5-9
 - High: 10-15
 - Critical: 16-25

Risk	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Level
Compromised login credentials because MFA isn't enforced	4	4	16	Critical
Customer financial data or PII could be exposed during the migration process.	4	5	20	Critical
Company falls out of compliance	3	4	12	High

with data protection rules				
Unauthorized users could gain access to the cloud-based CRM and view or modify sensitive customer information.	4	5	20	Critical
The company could experience data loss during the migration, leading to incomplete or missing customer records.	3	5	15	High

Part 4: Risk Mitigation Strategies (30 points)

For the three highest-rated risks from your assessment in Part 3, develop detailed risk mitigation strategies. For each risk:

1. Describe the risk mitigation approach (avoid, transfer, mitigate, or accept)
2. Provide specific controls or actions to implement
3. Identify the responsible stakeholders
4. Establish metrics to measure the effectiveness of the mitigation
5. Estimate the residual risk after mitigation (low, medium, or high)

Risk 1:

Risk Statement	If the cloud storage isn't configured properly, customer PII and financial records could end up exposed to the public without anyone noticing right away.
Mitigation Approach	Mitigate
Specific Controls/Actions	I would put in a tool that can continuously check the cloud environment for misconfigurations (a CSPM tool) so nothing sits exposed for long. Storage should also be set up from secure templates instead of being configured manually each time, and any change to permissions should need a second person to sign off before it goes live. I would also add a manual check every few months just to be safe.
Responsible Stakeholders	Cloud/DevOps team, IT Security team, and the Data Protection Officer since this touches PII directly.

Effectiveness Metrics	How many misconfigurations get caught and fixed within 24 hours, what percentage of storage is actually being monitored, and whether there are zero exposed storage instances by the end of each quarter.
Residual Risk	Low

Risk 2:

Risk Statement	Unauthorized users could gain access to the cloud-based CRM and view or modify sensitive customer information.
Mitigation Approach	Mitigate
Specific Controls/Actions	Implement multi-factor authentication (MFA) for all user accounts. Apply role-based access control (RBAC) so employees can only access the information they need. Enforce strong password requirements and regular password updates. Review user accounts regularly and remove unnecessary access.
Responsible Stakeholders	IT Security Team, System Administrator, Human Resources, and Department Managers.
Effectiveness Metrics	Percentage of users enrolled in MFA. Number of unauthorized access attempts detected. Regular access reviews completed on schedule. No successful unauthorized login incidents.
Residual Risk	Low

Risk 3:

Risk Statement	Employees logging into the cloud CRM with just a username and password makes it too easy for an attacker who's phished someone's credentials to get in.
Mitigation Approach	Mitigate
Specific Controls/Actions	Turn on MFA for every single account, no exceptions. Access should follow least privilege too, so people only get what they actually need for their role, not more. I'd also set up alerts for unusual login attempts, and access needs to be reviewed regularly instead of being set once and forgotten.

Responsible Stakeholders	IT Security team, whoever manages identity and access, and HR since they need to flag when someone joins or leaves so access gets updated on time.
Effectiveness Metrics	Percentage of accounts with MFA turned on (target 100%), number of suspicious login attempts caught, and how quickly access gets removed once someone leaves the company.
Residual Risk	Low

Submission Guidelines:

- 1. Save this document with the filename format:**
GRC101_Week3_Lab_FirstName_LastName.docx
- 2. Submit your completed lab assignment through the course learning management system.**
- 3. Due date:** [Instructor to specify]

Grading Rubric:

- **Part 1: Risk Management Concepts - 20 points**
 - **Part 2: Risk Identification Exercise - 25 points**
 - **Part 3: Risk Assessment Matrix - 25 points**
 - **Part 4: Risk Mitigation Strategies - 30 points**
- Total: 100 points**